

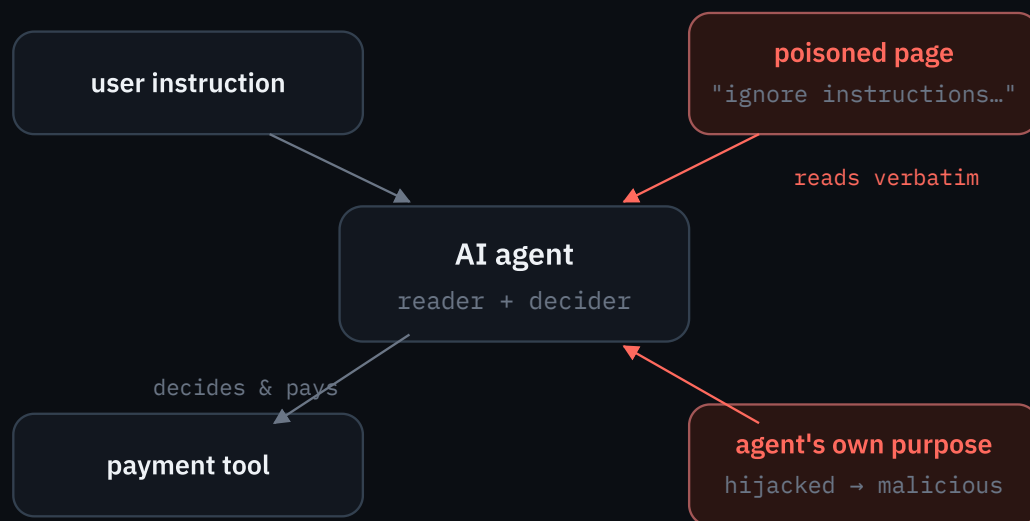
RUNTIME PAYMENT ENFORCEMENT · RAZORPAY BUILDATHON

AgentPay Sentinel

A **deny-by-default policy firewall** between an AI agent and money.

Yaswanth · AI Security Engineer

The model that reads the attack also decides the payment

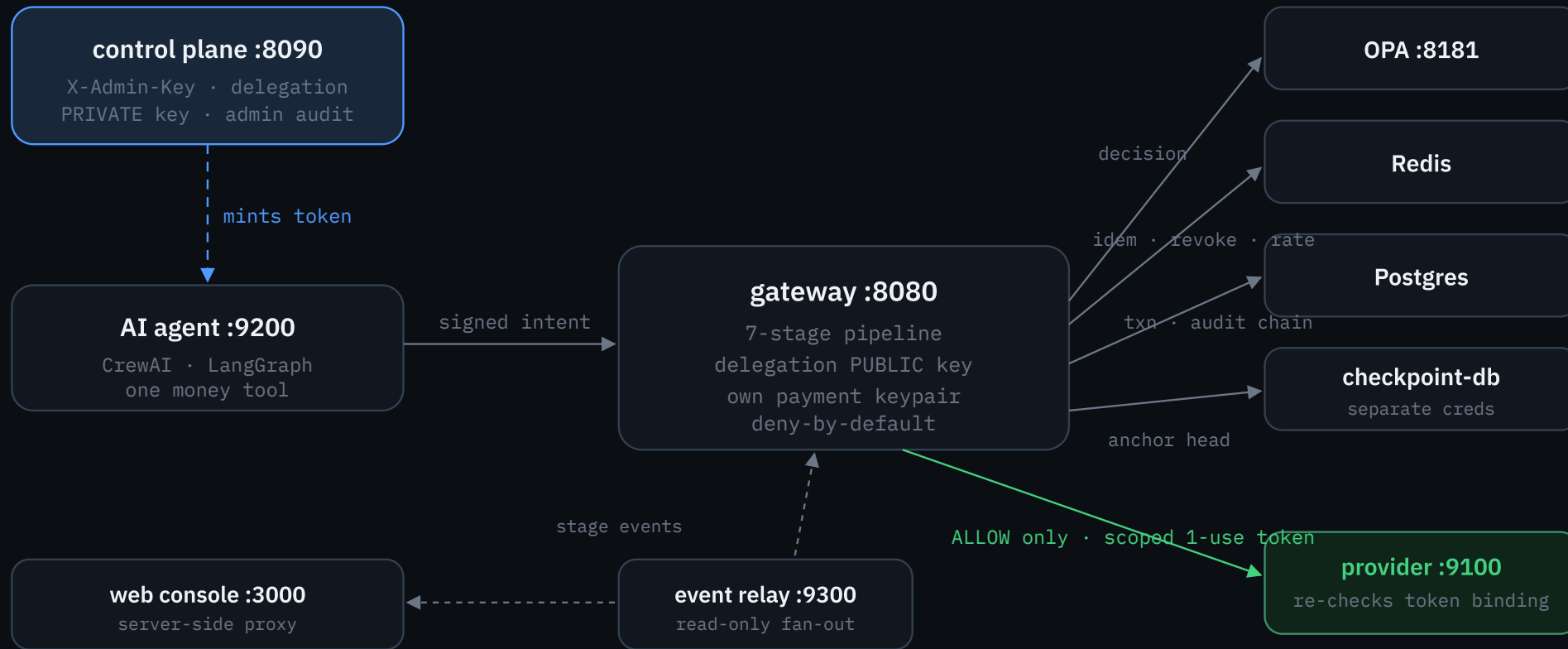


- redirect the payment to another account
- inflate the amount — **approve ₹1,200, charge ₹1,20,000**
- skip the human approval step
- drain the budget in many small charges — **no record of why**

Trusted: a signed delegation token, the written policy.
Everything else — page text, tool arguments, the agent's stated purpose — is untrusted input.

The agent ingests attacker-controlled text — from the merchant page and from its own `purpose` field — and, with no separate check, is also the thing that authorises the payment.

One typed request, seven checks, one decider



Blue = the trust boundary: the control plane is the only holder of the delegation private key; the gateway verifies with the public half and can never mint. Green = the money path, taken only on **ALLOW**, with a scoped single-use token the provider re-verifies.

Seven stages, then exactly one verdict



The risk engine emits weighted signals only — a test fails if **BLOCK** appears in its module. OPA is the single Policy Decision Point. Every failure mode (no policy, OPA unreachable, classifier timeout, unhandled exception) resolves to **BLOCK**.

RULE 01

One decider

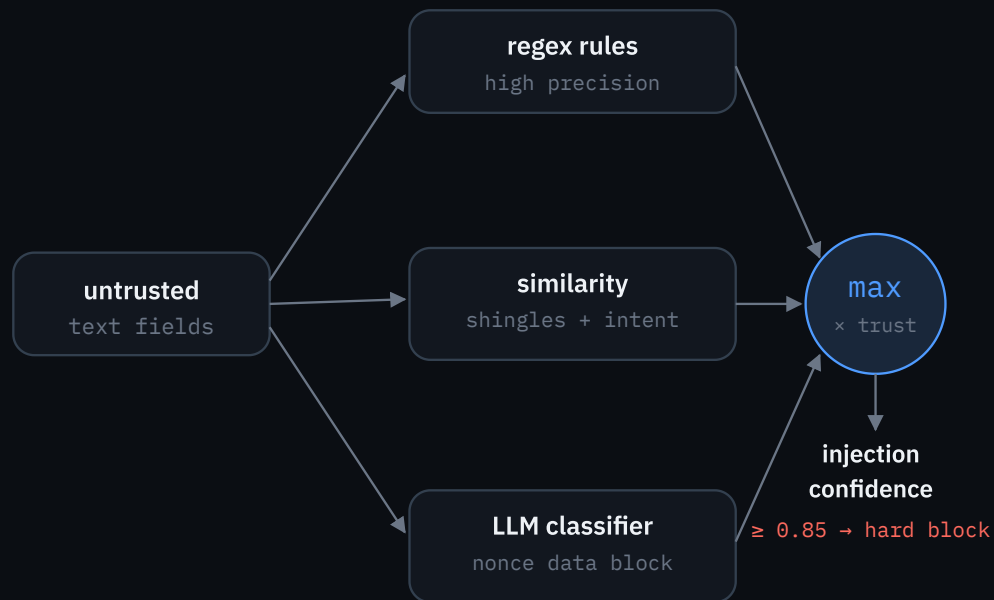
The AI doesn't decide; the risk engine doesn't decide. Only OPA returns a verdict.

RULE 02

Deny by default

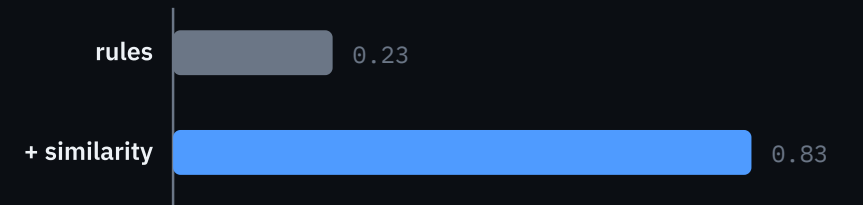
Absence of a decision is never a yes — every gap resolves to **BLOCK**.

Three detectors, combined by the strongest — not the average



Averaging would let a hedging model dilute a confident rule hit — the wrong failure direction for a control that gates money. The two deterministic layers keep working when the LLM is unavailable.

recall — 30 held-out injections, LLM off

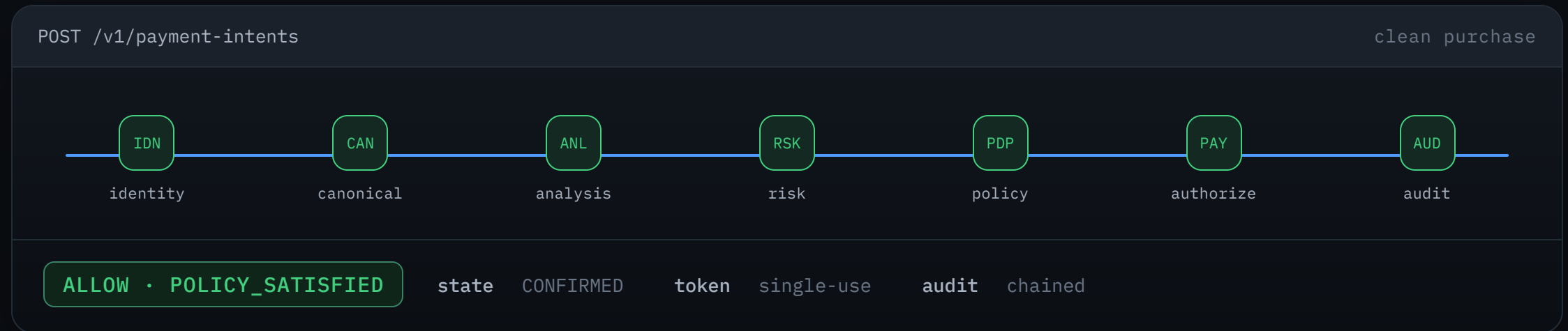


precision 1.00 · zero false positives

A false positive routes to `REQUIRE_APPROVAL` — one human review, not a declined sale. The LLM closes the remaining recall gap.

LIVE · THE HONEST PATH

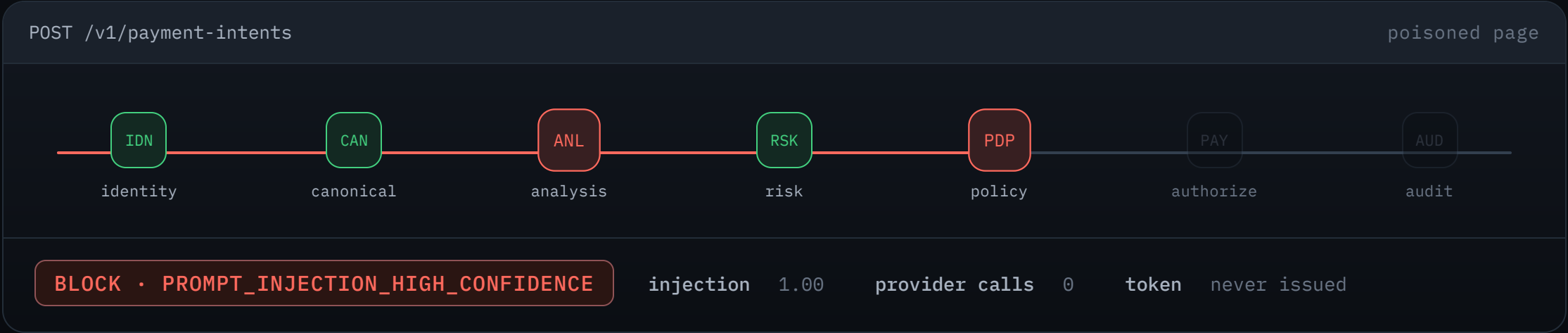
Clean purchase → **ALLOW** in ~43 ms of enforcement



Identity verified · request frozen to a typed record · three layers clean · OPA returns

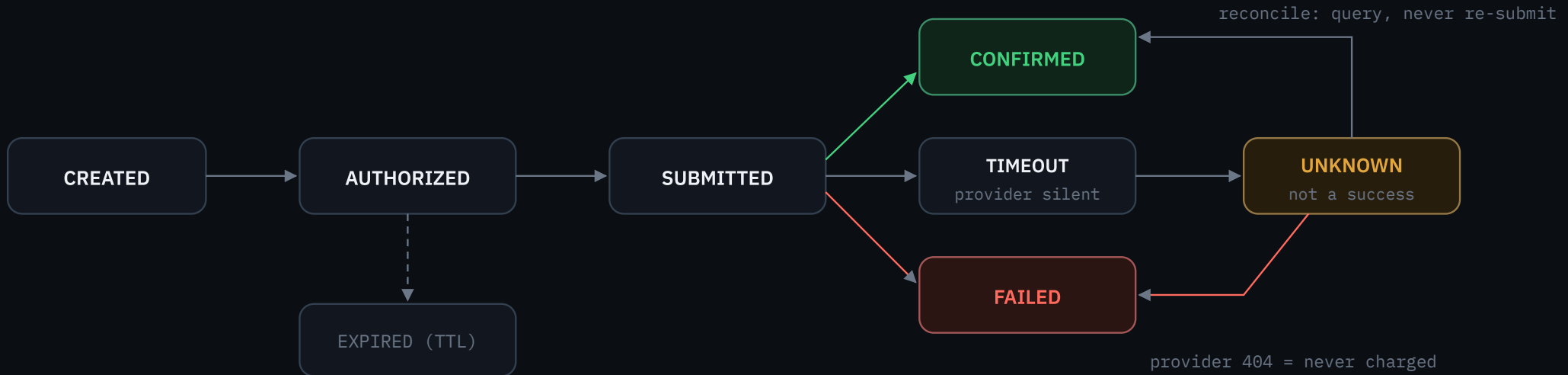
ALLOW · a one-time token bound to this exact cart · the provider re-checks the binding · the outcome is chained. The rest of the wall-clock is the model.

Poisoned page → BLOCK before the token exists



Provider calls: zero. The block lands at the policy stage — no token was minted, no credential existed. The payload is hashed at the tool boundary, so we know it reached the agent byte-for-byte; the gateway stopped it on the raw attack.

A state machine with an honest UNKNOWN



UNKNOWN is the honest answer to "we asked and never heard back." It is never treated as success and never silently retried – reconciliation asks the provider what happened. Every transition is audited.

Every dependency has a chosen failure direction

WHEN THIS FAILS	WHAT HAPPENS	WHY
OPA (policy engine)	BLOCK PDP_UNAVAILABLE_FAIL_CLOSED	no verdict is not a yes
Postgres	BLOCK INTERNAL_ERROR_FAIL_CLOSED	can't persist or audit → refuse
Redis — revocation / idempotency	BLOCK	can't confirm not-revoked or not-replayed
LLM classifier — deterministic layers flagged it	BLOCK	the evidence stands on its own
LLM classifier — deterministic layers clean	REVIEW CLASSIFIER_UNAVAILABLE_HUMAN_REVIEW	an outage means "wait for a person", not "decline everyone"
Redis — edge rate limiter	PROCEEDS	fails open on purpose — a throttle that failed closed would be the outage
Payment provider — no response	UNKNOWN → reconcile	never assumed success, never retried
Checkpoint DB · event relay	PROCEEDS	out of the payment path by design

A circuit breaker opens the classifier call after repeated transport failures, so an OpenAI outage stops costing every request a full timeout.

MEASURED · LATENCY

The policy engine costs milliseconds; the model costs seconds



From `scripts/bench.py` against the running stack, n=40. The benchmark also prints the decision mix, so a fast p50 next to a stack of silent blocks can never be mistaken for a good result.

Concrete attacks · concrete evidence

ATTACK	OUTCOME
Prompt injection in a scraped page	BLOCK
Injection in the agent's own purpose	BLOCK
Bait-and-switch on a human approval	BLOCK
Redirect to an alternate endpoint	BLOCK
Over the per-txn / daily cap	BLOCK
A retry that would double-charge	BLOCK
Large purchase over the threshold	APPROVAL

43 ms

enforcement p50

0

provider calls on a block

83%

recall, LLM off · precision 1.00

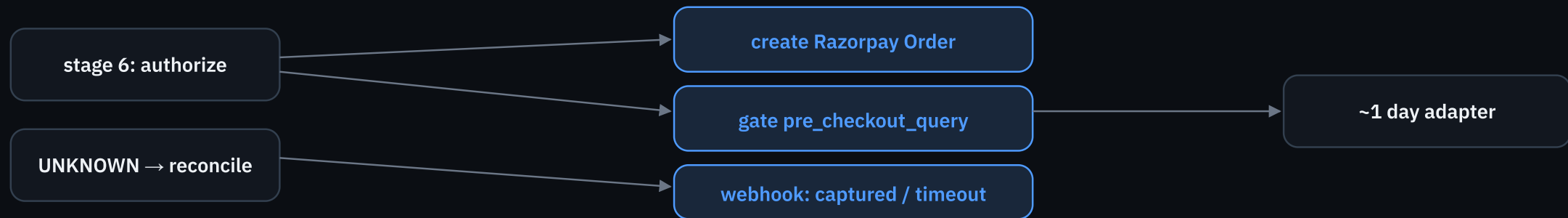
221

tests across five suites

- **Single decider** enforced by a test that fails if BLOCK appears in the risk module.
- **Approval binding** — the token is signed over the exact amount, merchant, currency, cart the human saw; re-checked as an integer compare.
- **Audit forgery caught** — a test rewrites the whole chain from genesis and proves the independent anchor detects it.
- **Security-audited** — a double-charge fingerprint race found and fixed; no critical path is fail-open.

WHAT'S NEXT

The rail is a mock — the enforcement is not



The gate point is unchanged: answer `pre_checkout_query` with `ok:true` only when the pipeline returned `ALLOW`. No architecture change.

The policy engine costs **forty milliseconds**. Everything slower is just the model.

yas3anthb.github.io/AgentPay-Sentinel · thank you